

Cybersecurity requirements for firewalls, intrusion detection and/or prevention systems

Deep Dive Session

EN 304 636

Presented by: Bruno Banelli
December 2025



Agenda

Session Overview

- CRA & Standardisation Request
- STAN4CR2 Project Context
- Standard Scope & Document Structure
- Risk Factor Framework

Deep Dive Content

- Technical Requirements
- Assessment & Verification
- Compliance Demonstration
- Areas for Stakeholder Feedback
- Q&A



CRA & Standardisation Request Overview

Cyber Resilience Act (CRA) Purpose

- CRA ensures products with digital elements are secure by design and resilient against cyber threats throughout their lifecycle.

Key Focus for Firewalls, IDS and IPS

- Not about basic functionalities - cybersecurity requirements
- Reduce impact on network if compromised
- Security by design from development through deployment

Harmonized Standards Benefits

- Reduce market fragmentation and help manufacturers efficiently meet regulatory expectations across the EU.
- Ensuring products are secure by design
- Identifying and mitigating vulnerabilities



STAN4CR2 Project Context

Harmonized Standards Development

- STAN4CR2 focuses on creating cybersecurity standards for different vertical products with digital elements to ensure CRA compliance.

Organizational Leadership and Funding

- ETSI leads the project through TC CYBER with funding from the European Commission and support from ENISA.

Collaborative Approach

- The project fosters collaboration amongst industry, regulators, and academia to address cybersecurity challenges and align with EU regulations.



ETSI EN 304 636 Scope

Product Coverage

- Firewalls
- Intrusion Detection Systems
- Intrusion Prevention Systems

CRA Classification:

- Important Products Class II (Annex III)



Document structure Overview

(most important sections)

Clause 4: Product Context

- Intended purpose and product functions
- Operational environment
- Risk assessment framework

Clause 5: Security Requirements

- Organised by requirement groups (DEFAULT, UPDATE, RESET, etc.)
- Triggered by applicable risk factors

Clause 6: Vulnerability Handling Requirements

- Vulnerability identification and remediation processes
- Security testing and disclosure procedures

Clause 7: Assessment Procedures

- Detailed verification methods for each requirement
- Evidence requirements and pass/fail criteria



Risk Assessment Framework

1. Risk Factors

- Cybersecurity risks manufacturers shall evaluate based on intended purpose, foreseeable use, and conditions of use

2. Risk Factor Assessment

Assess and document each risk factor's applicability:

- Applicable (Default) - present by default
- Applicable (Configurable) - present when configured
- Not Applicable - not present in product

3. Result

- Risk factors present in the product trigger corresponding security requirements in Clause 5 which is presented in mapping table

Risk Factor Categories

Baseline (BL-RF) - 7 factors

- Fundamental security properties for ALL products

Traffic Inspection (TI-RF) - 2 factors

- Passive monitoring or inline enforcement

Update and Intelligence (UI-RF) - 3 factors

- Manual updates, automated updates, threat intelligence

Deployment Architecture (DA-RF) - 2 factors

- Physical appliance or virtual deployment

Data Operations (DO-RF) - 1 factor

- Data transfer outside local environment



Baseline Risk Factors Summary

Why Baseline Factors Are Universal

- Foundational defence against undiscovered exploitable vulnerabilities
- Address fundamental security properties
- Apply to ALL firewalls, IDS and IPS regardless of deployment

Triggered Requirements Are Unconditional

- No configuration or deployment scenario exempts products from these controls
- Ensures minimum security baseline across the entire product category



Baseline Risk Factors

[BL-RF-1] Initial configuration risk factor

- Products shipped with insecure default configurations face immediate exploitation. Attackers scan for default credentials within minutes.

[BL-RF-2] Lifecycle transition risk factor

- Products retaining data during decommissioning expose credentials, keys, and topology to unauthorised parties.

• [BL-RF-3] Availability disruption risk factor

- Network infrastructure failures cascade through dependent systems. Products lacking resilience fail completely under attack.

Baseline Risk Factors

[BL-RF-4] System integrity compromise risk factor

- Boot process compromise enables persistent implants surviving software remediation. Products booting unsigned firmware cannot distinguish legitimate from malicious updates.

[BL-RF-5] Packet processing risk factor

- Products process millions of packets. Attackers craft malformed packets triggering buffer overflows, memory corruption, or undefined behaviour.

[BL-RF-6] Attack surface exposure risk factor

- Every exposed interface represents a potential attack vector. Debug interfaces (JTAG, UART, SWD) provide complete system control through physical access.

[BL-RF-7] Security event visibility risk factor

- Products lacking comprehensive audit logging operate as security blind spots. Products failing to persist logs across resets eliminate forensic evidence.

Baseline vs. Conditional: Why It Matters

Baseline Risk Factors [BL-RF-1] through [BL-RF-7]

- Apply universally to ALL products
- Make triggered requirements unconditional
- Every firewall, IDS, and IPS must meet these requirements

Conditional Risk Factors [TI-RF], [UI-RF], [DA-RF], [DO-RF]

- Apply based on product characteristics and deployment context
- Only applicable when risk factor is present



Risk Factor Mapping Table

Risk Factor Code	Risk Factor Description	Applicable Requirements
[BL-RF-1]	Initial configuration risk factor	[DEFAULT-RQ-*]
[BL-RF-2]	Lifecycle transition risk factor	[DEFAULT-RQ-*], [RESET-RQ-*]
[BL-RF-3]	Availability disruption risk factor	[DEFAULT-RQ-*], [AVAIL-RQ-*]
[BL-RF-4]	System integrity compromise risk factor	[DEFAULT-RQ-*], [UPDATE-RQ-*], [INTEGRITY-RQ-*]
[BL-RF-5]	Packet processing risk factor	[DEFAULT-RQ-*], [PACKET-RQ-*]
[BL-RF-6]	Attack surface exposure risk factor	[DEFAULT-RQ-*], [AUTH-1-RQ-*], [AUTH-2-RQ-*], [AUTH-3-RQ-*], [DATA-RQ-*], [EXPOSURE-RQ-*]
[BL-RF-7]	Security event visibility risk factor	[DEFAULT-RQ-*], [LOG-RQ-*]
[TI-RF-1]	Passive monitoring risk factor	[PACKET-RQ-*]
[TI-RF-2]	Inline enforcement risk factor	[AVAIL-RQ-*], [PACKET-RQ-*]
[UI-RF-1]	Manual update risk factor	[UPDATE-RQ-*], [SIGNATURE-RQ-*]
[UI-RF-2]	Automated update risk factor	[UPDATE-RQ-*], [SIGNATURE-RQ-*]
[UI-RF-3]	Threat intelligence exposure risk factor	[SIGNATURE-RQ-*]
[DO-RF-1]	Data transfer risk factor	[DATA-RQ-*], [TRANSFER-RQ-*]

Requirement Groups Overview

Clause 5

Core Security Controls

- [DEFAULT] - Secure by default configuration
- [RESET] - Factory reset mechanisms
- [UPDATE] - Security update mechanisms
- [AUTH-1/2/3] - Authentication, authorisation, sessions

Protection & Monitoring

- [DATA] - Data protection
- [AVAIL] - Availability and resilience
- [INTEGRITY/PACKET/EXPOSURE] - Attack surface mitigation
- [LOG] - Monitoring and logging



DEFAULT Requirements Overview

[DEFAULT-1-RQ-1-01]

- Applicable requirements may only be disabled in factory default state when enabled would render initial setup non-functional.

[DEFAULT-1-RQ-1-02]

- In factory default state, utilise only network interfaces and services necessary for product setup.

[DEFAULT-1-RQ-1-03]

- During initialization, limit access to accounts with initialization permissions.

[DEFAULT-1-RQ-1-04]

- Enforce the principle of least privilege during normal operation.



DEFAULT Requirements Overview

[DEFAULT-1-RQ-1-05]

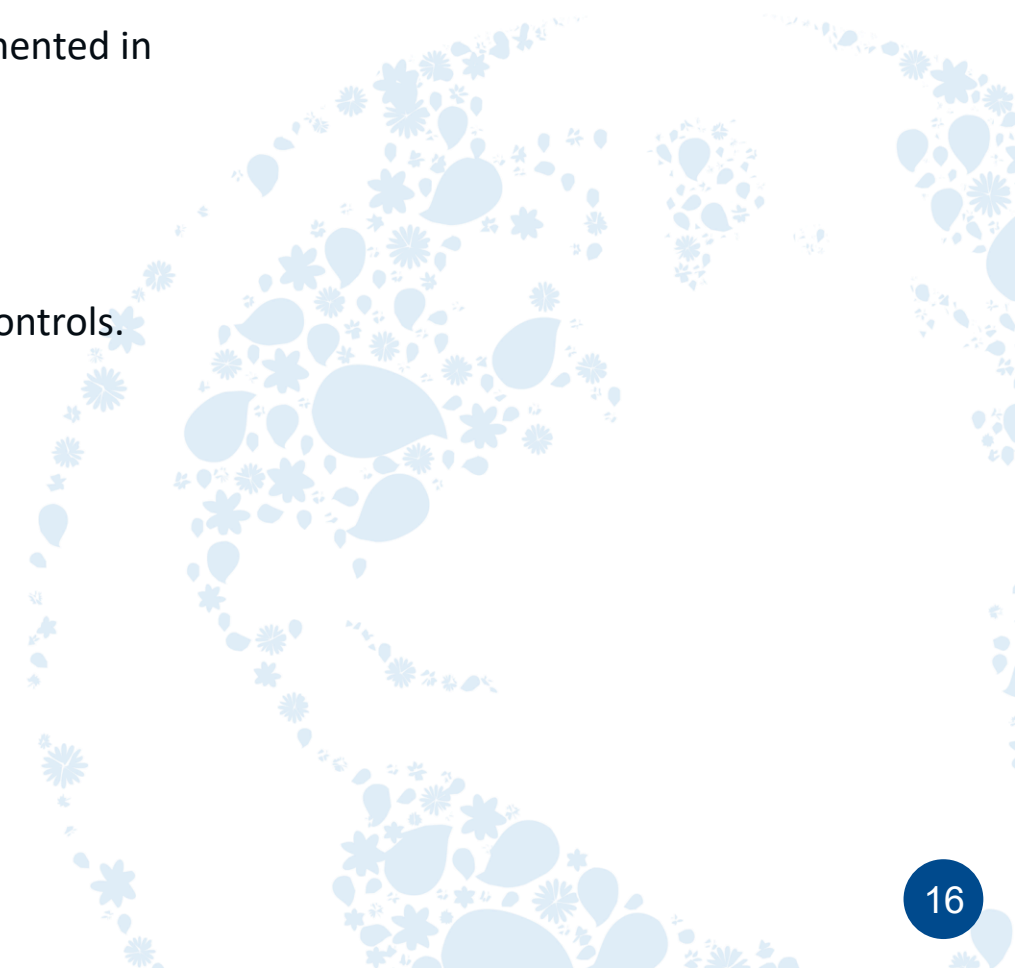
- In factory default state, allow access only using accounts and methods documented in instructions to the user.

[DEFAULT-1-RQ-1-06]

- Protect remote diagnostic interfaces with authentication and authorisation controls.

[DEFAULT-1-RQ-1-07]

- In factory default state, enforce change of administrative credentials.



DEFAULT Requirements Overview

[DEFAULT-1-RQ-1-08]

- In factory default state and before initialisation, have debugging and diagnostic interfaces disabled.

[DEFAULT-1-RQ-1-09]

- In factory default state, enable security audit events logging for authentication attempts, configuration changes, and product errors.

[DEFAULT-1-RQ-1-10]

- In factory default state, configure all cryptographic functions to use algorithms and key lengths that comply with current recognised standards.

[DEFAULT-1-RQ-1-11]

- In factory default state, disable any protocols or services that have known exploitable vulnerabilities.

RESET Requirements Overview

[RESET-1-RQ-1-01]

- Provide factory reset mechanism that restores secure-by-default configuration.

[RESET-1-RQ-1-02]

- Factory reset maintains currently installed firmware version and all applied security updates.

[RESET-1-RQ-1-03]

- Require authentication and authorisation at highest privilege level for software-initiated factory reset.

[RESET-1-RQ-1-04]

- Upon factory reset, not retain any information that could reconstruct previous configuration.

Assessment Procedure Structure

Clause 7

Components for each requirement:

1. Requirement Statement
2. Activities - Step-by-step verification:
 - review documentation, examine config, test functionality
3. Verdict - Clear pass/fail criteria
4. Supporting Evidence:
 - manufacturer documentation, configuration files, test results, log entries



Assessment Example:

Factory Reset

[RESET-1-RQ-1-01] Verify factory reset restores secure-by-default configuration.

Activities (Key Steps):

- ✓ Review manufacturer documentation for reset procedures and mechanism location
- ✓ Execute factory reset according to documented methods
- ✓ Verify all security settings restored to factory defaults
- ✓ Confirm all user data and configurations removed
- ✓ Test product functionality after reset

Verdict:

PASS if:

- ✓ Reset mechanism available and accessible
- ✓ Documentation describes procedure
- ✓ All security settings restored to secure defaults
- ✓ User configurations and data completely removed
- ✓ Product remains functional after reset

Assessment Example:

Factory Reset

FAIL if:

- ❖ Reset mechanism unavailable or undocumented
- ❖ Security settings not restored to defaults
- ❖ User data or configurations persist after reset
- ❖ Product becomes inaccessible or non-functional

Supporting Evidence:

- ✓ Manufacturer documentation of reset procedures
- ✓ Configuration comparison (pre-reset vs post-reset)
- ✓ Verification that secure-by-default state is achieved
- ✓ Evidence of complete user data removal



Compliance Demonstration Process

Step 1: Risk Factor Determination

- Manufacturer assesses all 15 risk factors

Step 2: Requirements Mapping

- Using mapping table: baseline → unconditional; conditional → when present

Step 3: Risk Factor Assessment Documentation

- Include in technical documentation and Declaration of conformity

Step 4: Evidence Collection

- For each applicable requirement: documentation, test results, configurations



Compliance Demonstration Example Product

Product: Basic hardware firewall appliance

Applicable Risk Factors:

- All 7 baseline [BL-RF-1] through [BL-RF-7]
- [TI-RF-2] Inline enforcement
- [UI-RF-1] Manual updates
- [DA-RF-1] Physical appliance

Triggered Requirement Groups:

- [DEFAULT], [RESET], [UPDATE], [INTEGRITY], [PACKET],
- [AVAIL], [AUTH-1/2], [LOG], [EXPOSURE]

Result:

- ✓ Manufacturer collects evidence for each requirement
- ✓ Third-party assessor verifies compliance using Clause 7
- ✓ Conformity declaration issued
- ✓ Presumption of conformity with CRA achieved



Key Principles

Design Philosophy

- Each requirement analysed for feasibility - implementation costs considered
- Risk factors create natural consequences
- Standard allows product diversity - simple products face fewer conditional requirements

Implementation Approach

- Requirements are objective and testable - third-party assessors can verify consistently
- Lifecycle perspective - compliance continues through updates and product evolution
- Based on real threat landscape



Areas Requiring Stakeholder Feedback

Your input is critical for:

- Risk factor completeness - additional product vulnerabilities to address?
- Requirement feasibility - implementable and cost-effective?
- Assessment procedures - verification methods clear and executable?
- Cross-vertical alignment - common approaches for cryptography, updates, SBOM, auth
- Product scope boundaries - clear managed vs unmanaged distinction

No clause is written in stone - all may be improved based on industry expertise.

How to Participate

Access Draft Documents

- ETSI Open Area: <https://docbox.etsi.org/CYBER/EUSR/Open>

Collaborative Technical Discussion

- ETSI Labs: <https://labs.etsi.org/rep/stan4cra>

Active Stakeholder Engagement

- Submit comments and propose improvements
- Engage in debates to refine standards
- Participate in open consultations



Q&A





Thank you for your attention!



Co-funded by
the European Union

Follow us on:

